

Cyber Risk Executive Briefing

First National Bank (Fictional) | Prepared for the Chief Information Security Officer | Ameer Khan — 4th Year CS @ University of Toronto

Assessment date	Issued	Basis
2026-09-21	2026-09-21	NIST CSF 2.0 · FAIR · OSFI B-10 / B-13 / E-21

Simulated organisation — illustrative data. First National Bank (Fictional) is not a real institution; every figure is modelled.

Executive Overview

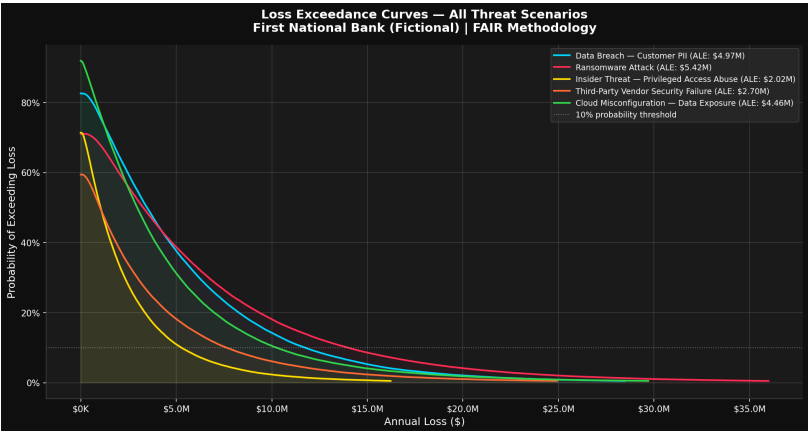
Across five modelled threat scenarios the bank carries **\$19.58M in expected annual cyber loss**. The control programme costed here runs at \$1.51M a year and would leave \$5.53M of residual expected loss — a \$14.05M reduction, or 72%.

Maturity is the constraint, not budget: **2.2 of 5.0** against a target of 4.0, with 4 of 6 functions below the defined level and Respond weakest at 1/5. Of 8 vendors, 1 is Critical-tier and 3 are past their reassessment window — a B-10 gap fixable this quarter without new spend.

Key Risk Findings

Scenario	ALE	90th %ile	Control cost	Residual ALE	ROSI
Ransomware Attack	\$5.42M	\$13.99M	\$500.0K	\$1.35M	713%
Data Breach	\$4.97M	\$11.74M	\$350.0K	\$1.49M	894%
Cloud Misconfiguration	\$4.46M	\$10.24M	\$180.0K	\$892.8K	1884%
Third-Party Vendor Security Failure	\$2.70M	\$7.63M	\$200.0K	\$1.08M	711%
Insider Threat	\$2.02M	\$5.27M	\$280.0K	\$706.0K	368%
Portfolio total	\$19.58M	—	\$1.51M	\$5.53M	830%

ALE is the mean of 100,000 simulated years. Residual ALE and ROSI rest on a 60–80% control-effectiveness assumption per scenario.

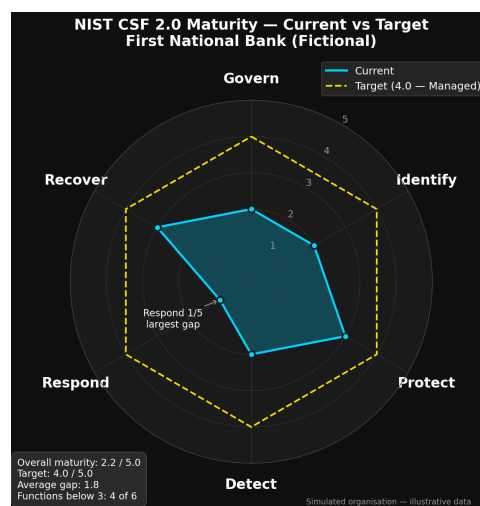


Loss exceedance curves — the probability that annual loss exceeds any given dollar amount, per scenario.

NIST CSF 2.0 Maturity

Overall maturity is **2.2 / 5.0** against a target of 4.0 — an average gap of 1.8 levels. A score of 3 means documented and consistently followed; 4 means measured and tracked with metrics.

Function	Current	Target	Gap	Status
Govern	2/5	4/5	2	Gap — below defined
Identify	2/5	4/5	2	Gap — below defined
Protect	3/5	4/5	1	At or above defined
Detect	2/5	4/5	2	Gap — below defined
Respond	1/5	4/5	3	Gap — below defined
Recover	3/5	4/5	1	At or above defined



Current maturity against the target of 4 across all six functions.

Top Three Recommendations

1. Fund the Ransomware Attack control set

Why	Largest single exposure in the portfolio: \$5.42M expected annual loss, \$13.99M in a 1-in-10 year.	
Action	Immutable offline backups tested quarterly; Network segmentation to limit lateral movement; Endpoint Detection & Response (EDR) on all devices.	
Cost	\$500.0K/yr	Effect — \$4.06M/yr reduction at 75% assumed effectiveness, leaving \$1.35M residual. ROSI 713%.

2. Close the Respond gap — 1/5 against a target of 4/5

Why	The weakest function. RS.MA-01 is cited by 2 of the 5 modelled scenarios, carrying \$6.99M of combined annual expected loss.	
Action	Create an Incident Response Plan. Include the OSFI 24-hour incident reporting step from the Technology and Cyber Security Incident Reporting advisory. Run a tabletop exercise within 90 days.	
Cost	~6 weeks of analyst effort; no new tooling	Effect — Raises the weakest function to the defined level and supports the \$6.99M of ALE that depends on it.

3. Remediate the Critical-tier vendor and clear the reassessment backlog			
Why	1 vendor sits in the Critical tier (Rideau Infrastructure Group) and 3 are past the reassessment window for their tier. OSFI B-10 expects monitoring proportionate to criticality.		
Action	Vendor security questionnaires and risk tiering (Critical/High/Medium/Low); Contractual security requirements in all vendor agreements.		
Cost	\$200.0K/yr	Effect — \$1.62M/yr reduction against the \$2.70M third-party scenario. ROSI 711%.	

OSFI Alignment Summary

Guideline / advisory	Status and key date	How this programme responds
B-13 — Technology and Cyber Risk Management	Effective 1 Jan 2024. Domains: Governance and Risk Management; Technology Operations and Resilience; Cyber Security.	CSF maturity scoring evidences control validation; the FAIR engine is the repeatable risk assessment.
B-10 — Third-Party Risk Management	Revised 2023, effective 1 May 2024.	Vendor questionnaire, tiering and audit trail. The 3 overdue reassessments are the open item.
E-21 — Operational Risk and Resilience Management	Full adherence expected by 1 Sep 2026. Scenario testing of all critical operations expected by 1 Sep 2027.	Recover scoring and the modelled severe scenarios start that testing programme.
Technology and Cyber Security Incident Reporting advisory	Reportable incidents reported to OSFI within 24 hours.	The Respond gap is the direct exposure: the 24-hour reporting path is undocumented and untested.

Vendor Risk Snapshot

Tier	Vendors	Reassessment cycle	Action required
Critical	1	90 days	No onboarding or renewal without a remediation plan. Executive approval required.
High	2	90 days	Retain with conditions; quarterly reassessment.
Medium	3	365 days	Standard monitoring; annual reassessment.
Low	2	730 days	Approved; biennial reassessment.

3 vendors are overdue for reassessment.

Vendor	Tier	Days since assessment	Window
Gastown Data Works	Medium	400	365 days
Rideau Infrastructure Group	Critical	220	90 days
Acadia Payment Networks	High	140	90 days

Portfolio average score 64.2/100. Weakest: Rideau Infrastructure Group at 34, with 3 critical gaps.